TRACK 03 · DEEPFAKE DETECTION FOR FINANCIAL COMMUNICATIONS

Satyapan

सत्यापन · “verification” in Hindi

Payment verification that a deepfake cannot pass.

ONE-SENTENCE SOLUTION

Satyapan makes a deepfaked CFO or vendor **unable to move money**: every payment is checked against the company’s own vendor master, the real executive’s voice and approvals carry a cryptographic **Satyapan Seal**, and any doubt hands verification to a person and channel the attacker does not control.

> **“A deepfake can copy a CFO’s voice, never his key.”**
> *Awaaz nakli ho sakti hai, mohar nahi.* (A voice can be faked; the seal cannot.)

REVIEWER MAP · RUBRIC CRITERION → PAGE

Problem fit and user (20)	**2, 3**	Safety, privacy, responsible AI (15)	**8, A3, X3**
Architecture and detection (20)	**4, 6, A1-A3**	Adoption and scale (10)	**10, A1**
Value and differentiation (15)	**3, 5, 6**	Evidence ledger, every number	**7, X1**
Feasibility and 48 h plan (15)	**7, 9, 10**	AI, data and asset disclosures	**X5**

CHALLENGE STATEMENT WE ANSWER

“Help people and institutions verify financial communications, detect manipulation, and create an actionable path for review, reporting, or response.”

Verify	Seal proves the real executive; master, the real account
Detect	provenance, forensic, behavioural signals, *raise-only*
Act	who verifies, checker hold, 1930 / NCRP / bank pack

TEAM · DELHI TECHNOLOGICAL UNIVERSITY (DTU)

Shivendra Narayan Tripathi	Lead · policy engine, Seal, capture
Saarika [surname]	Ask detection, side panel, voice
Kartikey [surname]	Email, invoice, voice checks, report
Saksham [surname]	Console, vault, OOB-Confirm, EN/HI

WHAT ALREADY RUNS (PROTOTYPE, 8 OCT 2026)

- Decision engine with property-tested safety invariants
- Satyapan Seal module, API, demo pages, side-panel chip
- Ask detection EN / Hinglish / Devanagari; EN + HI text
- 561 automated tests pass; gaps listed on pages 9 and X4

Synthetic and public data only. Every number is traced in X1.

The deepfake “boss scam” has reached India’s finance desks

IT IS HAPPENING IN INDIA, NOW

JULY 2026 · ₹10.70 CRORE · LISTED-COMPANY SUBSIDIARY [R1]

Starmangalsutra Pvt Ltd, a subsidiary of Sky Gold & Diamonds, disclosed that an employee sent funds to unknown accounts on instructions from an **impersonated director**. The company cited purported deepfake techniques and a compromised company phone and laptop. The director had given no such instruction.

17 JULY 2026 · SEBI CAUTION TO LISTED COMPANIES, PR 40/2026 [R2]

“Boss scam”: CEO/MD impersonation using **AI deepfakes and voice cloning on video calls**, hijacked WhatsApp Web sessions, the attacker’s number saved under the CEO’s name, and secrecy “because it is price-sensitive”. Then a mule account. SEBI’s advice: **call the senior directly, never transfer on a message alone, report on 1930.**

2024 · ARUP, HONG KONG · HK$200M (ABOUT US$25.6M) [R3]

An employee made 15 transfers after a video call with a deepfaked CFO and colleagues. The person who should have verified was the person being deceived.

> Scale: Indian citizens lost **₹22,845.73 crore** to cyber fraud in 2024 (Lok Sabha reply, 22 Jul 2025; mostly consumer fraud) [R4]. Corporate losses come on top, and most are never disclosed.

PRIMARY USER

Priya, accounts-payable maker at a ₹80-crore Pune manufacturer (illustrative). Pays vendors by NEFT / RTGS / UPI. Checker: **Arjun**. CFO: **Rajesh**.

HARMFUL MOMENT

Priya is about to pay a **new or changed bank account**, in a hurry and in secret, because “the CFO” or “the vendor” said so.

EXACT THREAT PATTERN

1 Impersonate	2 Ask	3 Pressure	4 Pay	5 Drain
deepfake voice or video, cloned profile	new account, “keep it confidential”, “skip Arjun”	the maker is also the one who would verify	NEFT / RTGS / UPI to a mule account	moved on in hours; needs the UTR fast

HARM

Loss of lakhs to crores in minutes. Recovery depends on reporting the transaction reference (UTR) within hours. Listed firms must disclose; Sky Gold’s shares fell on the news [R1].

SHARPLY BOUNDED PROBLEM

In scope: payment instructions reaching an SME or mid-market AP team by email, WhatsApp text or voice note, and browser meetings (Google Meet, Teams on the web).

Out of scope (MVP): consumer scams, phone-call interception, native Teams / Zoom desktop apps (upload the recording instead).

[R1] Sky Gold disclosure, Jul 2026 (Economic Times; AIID #1596) · [R2] SEBI PR 40/2026 · [R3] Fortune, May 2024 · [R4] Lok Sabha, 22 Jul 2025 · links: X6

Value and differentiation (15) · Problem fit (20)

Before and after: verification moves away from the person being deceived

	1 · INSTRUCTION ARRIVES	2 · CHECK	3 · VERIFY	4 · APPROVE AND PAY	5 · IF IT WAS FRAUD
TODAY Priya decides alone	"Rajesh" on Meet or WhatsApp: **urgent, confidential**, pay this new escrow account today.	Priya judges by **ear and face**. A detector, if any, gives a % that drifts with each new generator.	She calls the number in the message or her phone (attackers rename contacts [R2]). **The verifier is the person being deceived.**	"Approved" arrives by email or chat, which can also be faked. The amount or account can change afterwards.	Hunts for the UTR, the bank's fraud email and the NCRP form while the money moves on.
WITH SATYAPAN	Payment entered. **Floor from the vendor master:** new account ⇒ **VERIFY** whatever the message says.	Side panel: **"Claims to be Rajesh: NOT sealed"**. Asks: new account, secrecy, skip approval ⇒ **HOLD**	Only the **checker** may clear a HOLD, after his own callback on the number on file. OOB-Confirm reaches the **real** Rajesh.	Real Rajesh's passkey **signs the exact amount and account** (Intent Seal). Any change breaks the signature.	One click: **1930 script with the UTR on line 1**, bank fraud-desk email, NCRP draft, hashed evidence. A human submits.

USER VALUE

Priya **never has to judge whether a voice is fake**. Routine known-vendor payments add no step unless evidence raises them: 3.0% [1.4-6.4] of routine payments reached the checker in our synthetic test (n = 200, X1).

OTHERS DO	WHAT THAT GIVES YOU	WHAT SATYAPAN DOES DIFFERENTLY
Passive deepfake detectors (meeting, contact-centre and upload tools)	a probability that decays: on 2026 video generators the best detector scored 69.7% AUROC [R10]	**Proves the real executive** (Seal); no score is ever the gate
Meeting identity badges (Zoom + World ID beta, RealityCheck) [R16]	verify the *account*, on one platform; not the audio, not the payment	seals the **voice itself** to a passkey, this meeting, this 5 s; works for voice notes
In-band caller authentication research (CallShield, 2026) [R13]	about 63 s to authenticate; keys shared between contacts	5 s median verdict offline (X1); delayed key disclosure: receivers cannot forge
Callback and maker-checker (standard BEC hygiene)	right idea, done by hand, often skipped; number taken from the message	enforced and logged; number only from the master; **moved to the checker** when anything looks off

[R2] SEBI PR 40/2026 · [R10] DF26, arXiv 2609.07369 · [R13] CallShield, arXiv 2601.09327 · [R16] Zoom + World ID (May 2026), Beyond Identity RealityCheck (Aug 2024)

A trusted floor, raise-only evidence, and humans the attacker has not reached

TRUSTED · company's own data
maker's payment entry · vendor master · payment register · staff directory

UNTRUSTED · attacker can shape it
email · invoice PDF · WhatsApp text or voice note · live call audio

① Floor (fixed table)
new or changed bank account ⇒ **at least VERIFY**, however convincing the message

② Evidence signals
provenance: Seal, email origin · **forensic**: voice, PDF edits · **behaviour**: the ask

sets the minimum

can only raise

Band = the highest of the floor and every raised signal
two independent strong groups ⇒ HOLD · one uncorroborated ask ⇒ at most VERIFY · LLM or style ⇒ at most VERIFY · parse failure or detector error ⇒ at least VERIFY (fail closed)

PASS
pay normally; evidence and decision are logged

VERIFY
maker calls back on the number **from the master**, or sends OOB-Confirm

HOLD
checker only, after own callback + security sign-off; vendor edits frozen

③ Proof from the real requester, on his own device
OOB-Confirm or Intent Seal: "Did you ask Priya to pay ₹48,50,000 to ••••4821?" **"No, not me" ⇒ HOLD + suspected fraud.** "Yes" is recorded but never clears a HOLD on its own.

FLOOR TABLE IN PLAIN WORDS (TRUSTED INPUTS ONLY)

IF THE PAYMENT GOES TO...	FLOOR	BEFORE PAYING
known vendor, same account, usual amount	PASS	nothing extra
known vendor, unusual amount or dormant	VERIFY	callback or OOB-Confirm
new payee, ≤ ₹25,000 over 30 days	PASS	bank's own payee checks
new payee, above ₹25,000	VERIFY	callback or OOB (both > ₹10 lakh)
vendor's bank account changed	VERIFY	callback on the **old** number
phone, email or approver on file changed	HOLD	checker + 2nd approver

SAFETY RULES, PROPERTY-TESTED ON THE REAL ENGINE

- Untrusted content can only raise the band, never lower it.
- The floor reads only trusted data (fuzzed with hostile inputs).
- LLM or style signals: at most VERIFY, never "strong".
- No HOLD from one uncorroborated ask; only the checker clears HOLD.
- No code path files a report; a human always submits.

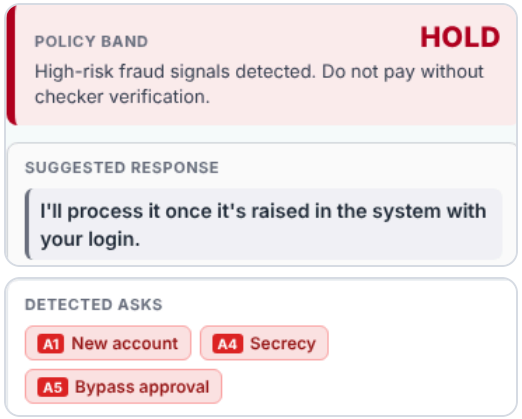
Detectors decide who verifies, never whether money to a new or changed account needs verifying.

A deepfake works by manipulating the person who would verify, so any strong signal moves the decision to someone else.

Policy engine: `src/satyapan/policy/` · invariants: `tests/invariants/` · signal → band table: X2 · ₹ thresholds configurable

Product walkthrough: from the live call to an approval nobody can alter

1 During the call: Priya's side panel · maker

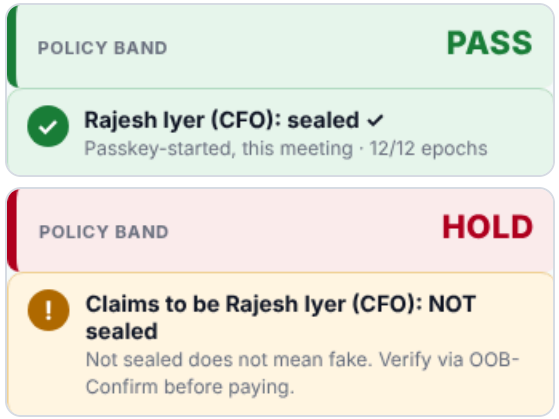


The band in plain words, a safe reply to read out, and the asks it heard: **new account, secrecy, skip approval**.

Priya never sees a score and never has to judge the voice.

BUILT side panel on **replayed** events of a synthetic call. Live Meet capture test: pending.

2 Who is really speaking? The seal chip · maker



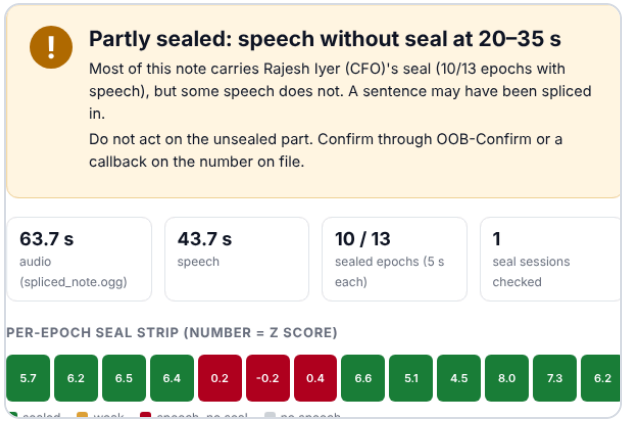
Real CFO on his enrolled laptop: **sealed** ✓ after about 5 s.

Clone: "NOT sealed" ⇒ VERIFY. With the secrecy and new-account asks ⇒ HOLD.

"Not sealed" is never called "fake".

BUILT chip + policy on replayed events; live in-call sealing: finale.

3 A forwarded voice note · checker view in the console

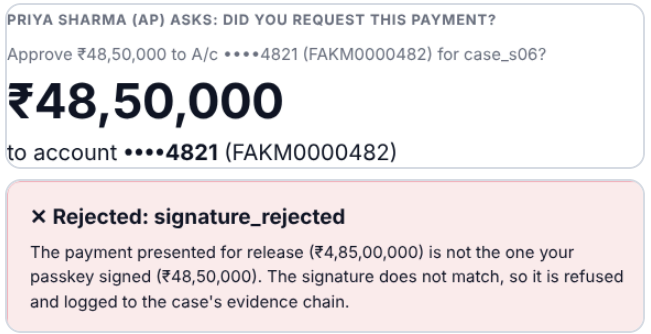


Each 5 s of a WhatsApp-style note is checked. A **spliced-in sentence shows as a red gap** (here 20-35 s).

Fully sealed note: "Sealed by Rajesh Iyer (CFO) ✓". No seal: "Not sealed: this does not mean fake".

BUILT real API, real Opus/OGG audio, synthetic voices.

4 The CFO approves on his own device · Intent Seal



Touch ID signs a hash of the **exact amount, account, case and a one-time nonce**.

Genuine approval: accepted. Amount changed to ₹4,85,00,000 afterwards: **refused and logged**.

BUILT virtual authenticator; approval alone never clears a HOLD.

5 Not yet built (finale, page 10): console case view, OOB-Confirm inbox, one-click UTR-first report pack (A2). All screens are the team's prototype: fictional people, companies and bank data; synthetic TTS voices.

Screens: `docs/pitch/round1/screens/`, made by `scripts/seal_screenshots.py` from the running API · seal numbers: page 6 and X1

Value and differentiation (15) · Architecture and detection (20)

Satyapan Seal: prove the real executive instead of chasing the fake

WHY DETECTION ALONE DECAYS

- On 2026 video generators the **best detector reached 69.7% AUROC**; one detector scored **34.5%** on closed-source generators (below 50% = worse than chance) [R10].
- Open-source detectors lost about half their AUC on real 2024 deepfakes; **audio −48%** [R11].

A seal does not decay: the attacker needs the key, not a better voice.

Not sealed ≠ fake

A missing seal only raises to **VERIFY**. A seal never lowers a band or clears a HOLD (property-tested).

HOW IT WORKS · ONE TOUCH ID PER MEETING

1. **Enrol once.** Rajesh (CFO) creates a passkey on his laptop. The server keeps only the public key.
2. **Start a meeting.** One Touch ID signs a commitment to a fresh chain of keys, bound to **this meeting ID**.
3. **Speak.** His client adds a faint keyed level pattern (±2 dB, 12 bands) to every **5 s** of his voice. Each key is revealed only **after** its 5 s end (TESLA delayed disclosure [R14]).
4. **Verify.** Priya's panel checks each 5 s with the revealed key: **"Rajesh: sealed ✓"** or **"Claims to be Rajesh: NOT sealed → verify"**.



Intent Seal. For money, the same passkey signs SHA-256 of the exact **amount + beneficiary + case + nonce + expiry**. Any later change breaks it (page 5, step 4).

ATTACK	RESULT
Voice clone / live voice conversion	**not sealed**
Replay of an earlier sealed call	**not sealed**
Relay of live audio from another meeting	**not sealed**
Another exec's valid seal, posing as him	**shows who sealed**
Listener forging a later 5 s	**key not yet out**
Malware on the CFO's own laptop	**not defeated**
Never-enrolled caller (phone, guest)	**not sealed → callback**
Fake voice mixed in with the real CFO	**partly**

Nearest prior work: CallShield, ~63 s, shared keys [R13]; Zoom badges verify the account, not the audio [R16]. Full threat table: X3.

MEASURED ON THE IN-REPO MODULE · SYNTHETIC TTS VOICES, N = 10 (6 ENGLISH, 4 HINDI) · ILLUSTRATIVE, NOT A FIELD RESULT

0 / 560
attack sessions falsely sealed (clone, relay, replay, wrong identity)
95% CI upper bound 0.7%

139 / 140
genuine sessions verified, 14 real codec chains
Opus 16k (WhatsApp-style), AMR-NB 12.2, G.711, 5% loss

5 s
median time to verdict
10 s Opus 8k; 20 s worst mobile mode

4 / 4
sealed through real Chrome WebRTC
noise suppression, AGC, echo cancel on and off; n = 2 voices

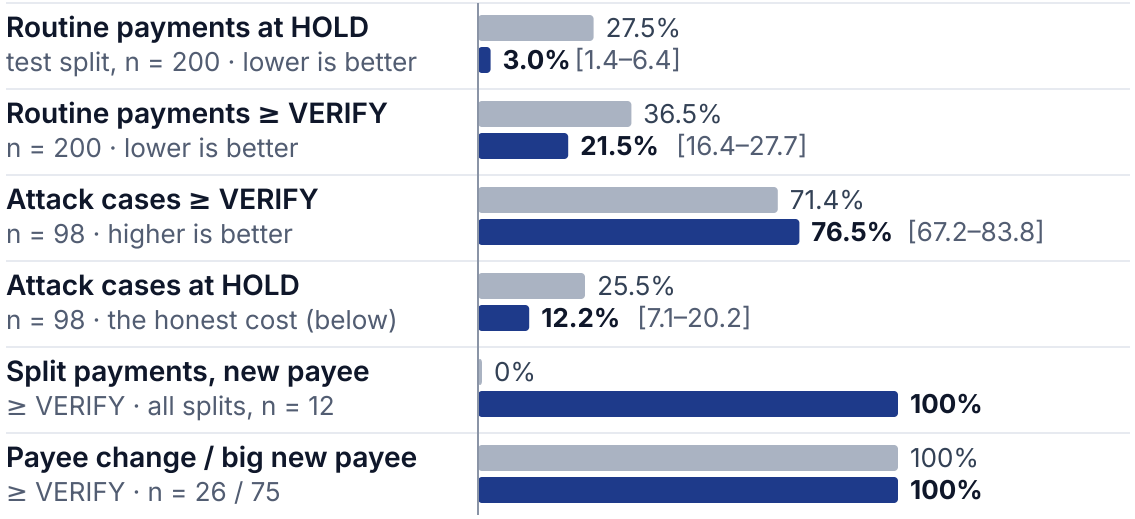
4.61
PESQ-WB with seal; plain Opus 32k: 4.46
audibility proxy; listening test pending

English and Hindi voices behave alike. **Untested: Google Meet's own server-side and ML noise cancellation** → finale test #1 (page 10). Weak spot: a constant 3% time-stretch (X1).

Evidence: what we measured, and why no content detector decides alone

ALERT BUDGET · THE REAL DECISION ENGINE ON 400 ROUTINE + 184 ATTACK SYNTHETIC PAYMENTS

before: policy 1.0 after: policy 1.1 + context layer (built)



HOW TO READ THE ATTACK HOLD DROP (COMPUTED BY THE SCRIPT)

Of 13 test-split attack cases that lost HOLD, **9** had been held only by a standard confidentiality footer (the same false positive that hit routine payments) and **4** are real single credential asks with no payment, now VERIFY. All stay at VERIFY or above except **1**, a remote-access ask the lexicon misses, which fell to PASS.

ASK DETECTION ON HELD-OUT TEXTS · FROZEN LEXICON · TEST SPLIT

0.47
precision [0.36–0.58], 73 flagged

0.33
recall [0.24–0.42], 104 asks

21.0% → 11.5%
benign texts with a false ask, n = 157 (context layer)

Recall by language (all splits): English 0.28, Hinglish 0.36, Devanagari **0.15**. These replace an earlier, circular P = R = 1.0 on team-written sentences.

Content detectors are brittle and easy to paraphrase around. That is why they can only raise the band, and why the floor and the Seal carry the decision.

RED-TEAM, DETERMINISTIC · ROUTINE PAYMENTS, N = 200

One planted secrecy word → HOLD	100% → 20.5%
Planted OTP-SMS or disclaimer line → HOLD	100% → 3.0%
Two planted keyword types → HOLD (**queue flooding: open**)	**still 100%**
Asks hidden by a boilerplate wrapper, n = 38	5.3%
Known gap: “bank never asks for OTP … but <ask>”, n = 38	**34.2% hidden**

PENDING: NO NUMBER YET, NEVER SHOWN AS A RESULT

Seal through a real Google Meet call · voice-detector error rate through Meet and phone codecs · false alarms per speaker on consented Meet audio · clone catch rate in a real call · spoken ask → chip latency · email and invoice checker rates. Earlier simulated voice numbers were **withdrawn** (X4).

Engineering evidence: 561 automated tests pass (138 skipped = unfinished tasks, X4). Safety rules are property-tested on the real engine (200 random cases each): raise-only, floor isolation, LLM cap, grey and OOB rules, no HOLD from one weak signal. Plain tests cover checker-only clearance, score hiding, no auto-reporting, custody chain.

Synthetic data: AI-written held-out texts (one author), cases built from them; Wilson 95% CIs; test split quoted because rules were tuned on dev texts · scripts, commits: X1 §1-3

Build for Trust: the brief's five questions, answered

1 · What data do you need?

- **Payment entry, vendor master, payment register, directory**: set the floor and the only callback numbers (company records).
- **Email, invoice, voice note** the user chooses to attach: can only raise.
- **Remote tab audio**, only while Priya turns protection on: asks + seal check; not stored unless she saves 30 s as evidence.
- **Executives' passkey public keys** and 32-byte seal keys: opt-in, own Touch ID.

We do not collect: voiceprints or any biometric, video, the user's own mic, bank logins or OTPs, customer data, other tabs, contacts.

2 · What happens when the system is wrong?

- **False alarm:** the worst case is "verify before paying". No auto-block, no accusation; one uncorroborated ask → at most VERIFY. Routine payments at HOLD: 3.0% (synthetic, n = 200).
- **Missed attack:** the floor still applies; a new or changed account always needs verification.
- **Real CFO not sealed** (on his phone): friction, not harm → normal callback.
- **Correction:** checker clears with a logged reason, can remove watchlist entries; monthly false-alarm review.

3 · Who can act on the result?

- **Maker:** clears VERIFY by callback on the number on file or OOB-Confirm.
- **Checker:** the only role that clears HOLD, after own callback + security sign-off.
- **Checker / security:** mark confirmed fraud. A **human** files 1930 / NCRP / bank reports.
- **Urgent override:** two senior approvers, reason, review in 48 h; never on suspected fraud.
- **Small firm** where the owner is the target: CA or bank RM as second verifier (design).

4 · How will users understand the result?

Band + plain reason + next step, in English and Hindi for all 33 reason codes. **Never a bare score.**

> "The bank account differs from the vendor master. Call the vendor back on the number already on file (not the one in the message) before paying."
>
> "बैंक खाता वेंडर मास्टर से अलग है। भुगतान से पहले वेंडर को पहले से दर्ज नंबर पर फिर से कॉल करें (संदेश वाले नंबर पर नहीं)।"

Seal text says "Not sealed does not mean fake". An optional LLM summary must pass a faithfulness check and never sets the band.

5 · How will the product resist misuse?

- **Oracle tuning:** makers never see scores; no public upload endpoint.
- **Prompt injection:** the LLM has no tools, sees untrusted text only as data, cannot set or lower a band.
- **Adaptation:** floor and Seal do not depend on detector quality; red-team numbers on page 7.
- **Evidence access:** role-checked reads, hash-chained custody; in production S3 Object Lock + KMS, CloudTrail.
- **Privacy abuse:** nobody can seal another person's voice without that person's passkey; keys expire.

Bias, consent and notice

- **Seal:** its false-alarm statistics do not depend on voice, accent or language; English and Hindi voices measured alike.
- **Detectors:** Devanagari recall is weakest (0.15). Before any voice threshold goes live: false alarms per speaker on consented Meet audio, ≥ 4 accents. "Inconclusive" never escalates alone; unsupported language → checker.
- **Notice:** staff policy notice; execs opt in per meeting; meeting-chat notice to the other side (design).

Data-flow table with lawful basis (DPDP Act 2023, Rules 2025 [R7]) and retention: X3 · roles: `policy/permissions.py` · EN/HI text: `explain/templates.py`

Validation plan: each assumption has a test, a pass mark and a status

① Offline DONE
Codecs, WebRTC, held-out texts, alert budget, red-team (pages 6-7).

② Lab FINALE
Two laptops on Google Meet, consented voices, listening test.

③ Shadow pilot · 2 weeks
One SME or CA firm, log only, real AP traffic. Pass: routine HOLD ≤ 5%.

④ Live with KPIs
VERIFY-only, then full HOLD; monthly false-alarm review.

#	ASSUMPTION	WHY IT MATTERS	HOW WE VALIDATE IT (PASS MARK)	STATUS TODAY
1	**The seal survives Google Meet**, incl. its server side and ML noise cancellation	live Voice Seal depends on it	two laptops, Meet noise cancellation on and off, sealed + unsealed files (median z ≥ 4; controls not sealed)	PENDING Chrome client path passed (n = 2 voices)
2	**The seal is inaudible** at ±2 dB	executives will not accept artefacts	blind A/B by 3 listeners, 1.5 vs 2.0 dB; use 1.5 dB if 2.0 is heard	PENDING PESQ proxy 4.61
3	**Executives enrol** and start a sealed session	covers the people attackers impersonate	time 3 enrolments and session starts (under 2 min each)	PENDING
4	**The vendor master is trustworthy** when a vendor is first added	it is the floor's trust root	first bank/phone record checked out of band: GSTIN lookup, penny drop, number from GST/MCA records, never from the vendor's email	DESIGN not built
5	**A payment-register export exists** (Tally / Zoho / SAP CSV)	30-day split rule, amount patterns	import one anonymised export in the shadow pilot	BUILT synthetic CSV only
6	**Routine escalation stays low** on real traffic	alert fatigue kills adoption	shadow mode: routine HOLD ≤ 5%, routine VERIFY trend down	3.0% synthetic; real pending
7	**Live Hinglish speech-to-text** is good enough to see asks	ask chips during calls	10 consented clips: spoken ask → chip latency and ask recall	PENDING
8	**The voice detector adds value** through Meet and phone codecs	forensic signal (raise-only)	public set × 4 codecs; false alarms per speaker on consented Meet audio	PENDING simulated numbers withdrawn
9	**The checker is not the person impersonated**	HOLD independence	small-firm setting: CA or bank RM as second verifier, or cooling-off	DESIGN

If #1 fails (Meet destroys the seal even at 2.5 dB or 10 s epochs): Intent Seal, sealed voice notes and the floor still work unchanged; the live chip falls back to a spoken session code (design). **Nothing else depends on the voice detector.**

Test procedures: `research/seal/README.md` §6 (two-laptop Meet test, listening test) · full gap list and what is not built: X4

Adoption path, and 48 hours in which every block ends in a proof

OWNER AND USERS

The **finance controller / CFO** buys and runs it. **Makers and checkers** use it daily; 3-10 payment approvers enrol a passkey. IT force-installs the extension through **Chrome Enterprise policy**.

INTEGRATION

Vendor master + payment register as a nightly **Tally / Zoho / SAP CSV** export; SSO directory; OOB by email / SMS. **No bank API needed**: the maker types the payee name the bank shows.

DISTRIBUTION

① Banks offer it to **SME current-account** customers with corporate net banking · ② Tally / Zoho marketplaces · ③ **CA firms** that run payables for many SMEs.

ROLLOUT

Shadow 2 weeks (log only) → **VERIFY-only** → **full HOLD**. Intent Seal for approvers in week 1, Voice Seal for executives in week 2.

KPIS AND FRICTION

Routine HOLD rate (≤ 5%) · median time to clear · approvers enrolled · prevented-loss log. Friction: one Touch ID per meeting; nothing for receivers; seal verdict ≈ 5 s (offline). Teams / Zoom desktop: use the browser client or upload the recording.

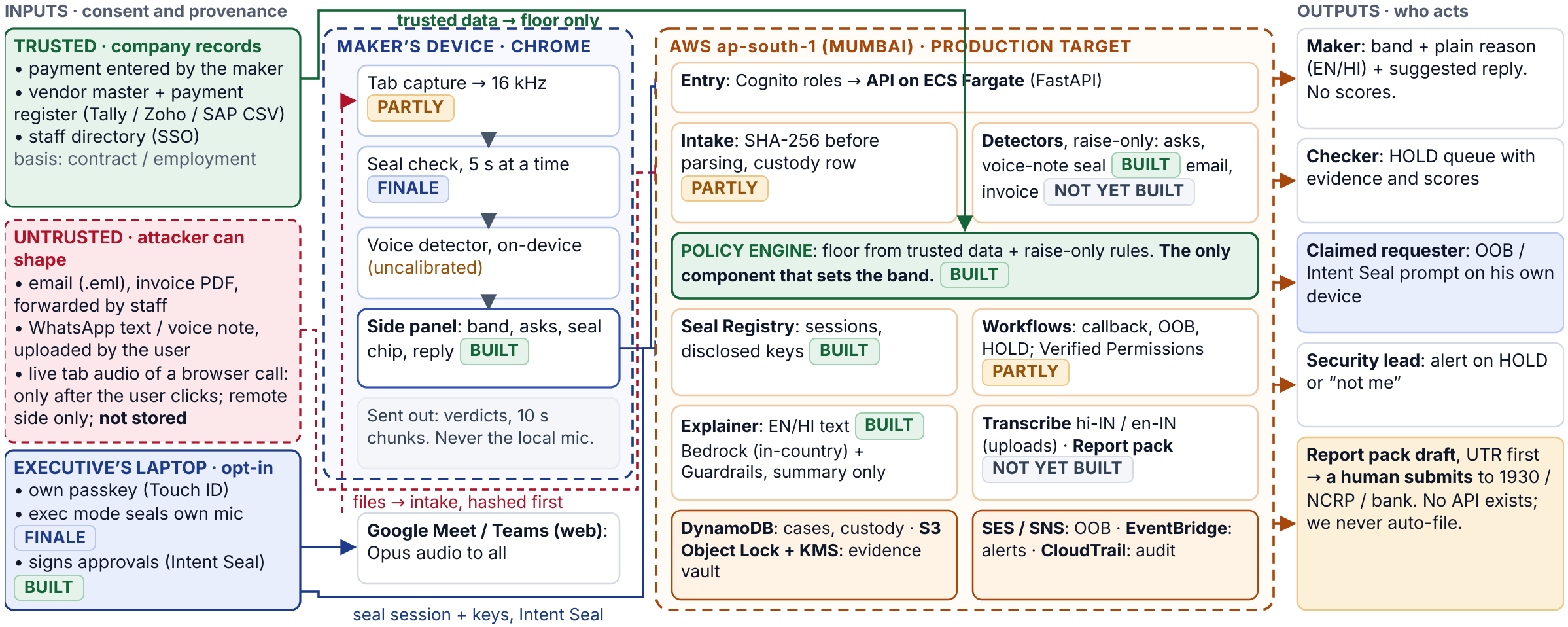
48-HOUR FINALE PLAN · OWNERS: SHIVENDRA (S), SAARIKA (SA), KARTIKEY (K), SAKSHAM (SK)

HOURS	WE BUILD	PROOF SHOWN TO JUDGES
0-4	**Test #1: two-laptop Google Meet seal test**, noise cancellation on/off; listening test (S, Sa)	z per 5 s on screen; go / no-go for the live seal
4-14	Exec-mode sealing (AudioWorklet) + seal check inside the extension (S); live chip (Sa)	real Meet: “Rajesh: sealed ✓”, then the clone laptop: “NOT sealed”
4-14	OOB-Confirm + Intent Seal as a clearance method, email / SMS (Sk)	a judge taps “No, not me” on a phone → case turns HOLD + suspected fraud
14-24	AWS ap-south-1: API on ECS Fargate, DynamoDB, S3 Object Lock + KMS, Cognito roles, Verified Permissions (K, S)	live URL; the maker’s “clear HOLD” is refused and logged in CloudTrail
24-34	Email + invoice checks on the fixture files; console case view; UTR-first report pack (K, Sk)	raw .eml / PDF in → floor catches what detectors pass; 1930 script, UTR on line 1
34-42	Judge red-team station (all)	judges speak their own scam lines: asks may be missed, floor and seal still hold
42-48	Shadow replay of the 584 synthetic cases; 10 dry runs; backup recording (all)	alert-budget dashboard; demo runs end to end

Dependencies we control: two laptops + a virtual mic (BlackHole), consented teammate voices with signed forms, an AWS account in ap-south-1, Chrome. **None on banks, I4C or Google**: no external API is assumed.

Fallbacks: Meet kills the seal → local call tab + sealed voice notes + Intent Seal, said openly · AWS slow → the same code in local mode · WebAuthn trouble → OOB-Confirm token. The seal only *adds* signals, so the core demo never depends on it.

A1 · One system: trusted data sets the floor, everything else can only raise it

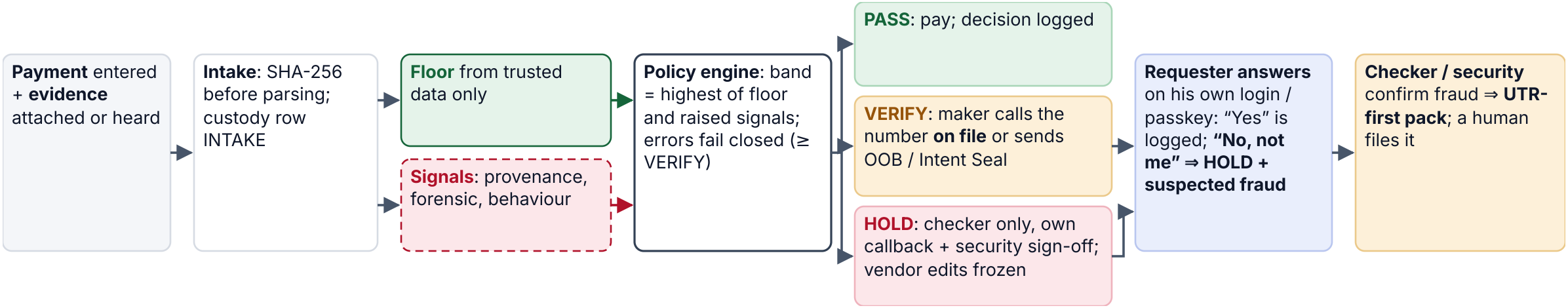


Retention: live audio not stored (user may save 30 s) · evidence 90 days or life of case · seal registry: meeting ID, timing, 32-byte keys, life of case · Bedrock: no prompt storage by default [R17] · all data in India (ap-south-1; Bedrock "in." profile routes only Mumbai ↔ Hyderabad).

Runs today, locally: FastAPI + policy engine, asks + context layer, Seal module + registry API + voice-note check + Intent Seal, side panel, EN/HI text. **Nothing is deployed on AWS yet**; tags show prototype status.

Architecture (20) · Safety (15)

A2 · From signal to decision to a human, with an evidence record at every step



ALERTS AND NOTIFICATIONS

EVENT	WHO IS TOLD, HOW
band rises during a call	maker: side-panel chip + reply line
case at VERIFY / HOLD	maker / checker: console queue
OOB or Intent Seal request	claimed requester: email / SMS (SES / SNS) → his own login + passkey
HOLD, or "No, not me"	security lead: EventBridge rule → email / SMS
any status change	custody row + CloudTrail

Alert budget: one uncorroborated ask never reaches the checker queue (page 7).

EVIDENCE PATH · TAMPER-EVIDENT CUSTODY CHAIN

INTAKE	ANALYSIS	DECISION	CLEARANCE
hash first	detector, seal	band, reasons	who, how

Each row stores SHA-256(previous row + this row). The chain head is written to **S3 Object Lock** every 15 min and on every status change (production). The **seal verification record** (session, 5 s epochs, scores, key-chain proof) adds *who produced the speech*.

What we claim: integrity since capture, plus seal provenance. Not "proof of fraud". BUILT chain core NOT YET BUILT S3 anchor

GOLDEN-HOUR REPORT PACK · UTR FIRST

1. **Call 1930**: script with UTR, amount, time and beneficiary on the first line.
2. **Bank fraud desk**: pre-filled email asking to hold the funds.
3. **NCRP** (cybercrime.gov.in) complaint draft + evidence index with hashes.

Only checker / security can generate it. **A human submits; no API to 1930 or NCRP exists, and we never fake one.** NOT YET BUILT

Clearance and roles: `policy/clearance.py`, `policy/permissions.py` · custody: `vault/custody.py` · [R8] cybercrime.gov.in / 1930

A3 · Mitigations, performance assumptions and how we validate them

RISK	MITIGATION	EVIDENCE / STATUS
Perfect deepfake fools every detector	floor from trusted data; detectors only raise; Seal proves the real executive	invariant tests; 0/560 false seals
Manipulated maker calls the attacker's number	callback number only from master or directory; strong signal moves it to the checker	invariant tests BUILT
Prompt injection in mail, PDF or speech	LLM has no tools, fixed system prompt, never sets the band; output checked	tests; reassuring text passing 100% → 36.7% (n = 30)
Attacker tunes fakes against our output	makers see bands, never scores; no public upload	invariant test
Insider maker clears his own HOLD	role check; in production also Verified Permissions (Cedar)	invariant test; AVP finale
Checker-queue flooding	one uncorroborated ask capped at VERIFY	1 word: 3-21%; 2 types: 100% **open**
Splitting under ₹25,000	30-day total per new payee from the payer's register	12/12 splits ≥ VERIFY
Seal replay, relay, forgery	bound to meeting + 5 s epoch; keys disclosed only after use	0/560 false seals
Compromised exec laptop or browser	Touch ID per session, Intent Seal per payment; SPC-style amount display (future) [R15]	**not defeated**, stated
Evidence tampering or snooping	hash at intake, custody chain, Object Lock + KMS, role-checked reads, CloudTrail	chain BUILT; AWS finale
Over-collection, data leaving India	no voiceprints; live audio not stored; ap-south-1 only; Bedrock in-country	design + DPDP table (X3)
Extension abuse	captures one tab only after a click; never the mic; enterprise-managed install	capture code built; Meet test pending

PERFORMANCE ASSUMPTIONS

Seal verdict	5 s median (10 s Opus 8k)	MEASURED
Seal check compute	≈ 6 ms per call recording (Python)	MEASURED
Key disclosure delay	≤ 1 s after each 5 s	DESIGN
Voice window	5 s audio; ≈ 2.8 s compute in Node	CHROME PENDING
Spoken ask → chip	≤ 13 s budget	PENDING
LLM	never in the live loop	DESIGN
Cost per case	< ₹1 non-live; ≈ ₹2 per live call-minute (Transcribe)	ESTIMATE
Scale	32-byte key per 5 s per speaker; table lookup per case	DESIGN

VALIDATION APPROACH

- **Done:** 561 tests incl. property tests of the safety rules; held-out texts; alert budget through the real engine; deterministic red-team; real codecs (ffmpeg, sox) and real Chrome WebRTC for the Seal.
- **Next:** two-laptop Meet test, listening test, latency in Chrome, then a 2-week shadow pilot (page 9).
- Every number has a script, commit, n and CI in X1. Estimates are labelled.

Full threat model and DPDP data flows: X3 · [R15] W3C WebAuthn / Secure Payment Confirmation · cost basis: Transcribe list price, to be re-checked for ap-south-1

Every number in this PDF

X1 · Every number, with its n, interval, script and status

PAGE	CLAIM	VALUE	N	95% CI (WILSON)	PRODUCER → OUTPUT · COMMIT	STATUS
3, 6	Attack sessions falsely sealed (4 attack types)	**0 / 560**	560	[0–0.7%]	`research/seal/run_codec_eval.py` → `seal_summary.json` · d6ae619 / bb92393	measured†
6	Genuine sessions verified, 14 codec chains	**139 / 140**	140	[96.1–99.9%]		measured†
6	Attack scores per 5 s: mean / std / max; ≥ 4	+0.04 / 1.03 / 3.13; 0	3,920	—		measured†
3, 6	Median time to verdict (most chains)	5 s	10 / chain	—		measured†
6	Chrome WebRTC on/off: sealed; controls sealed	4 / 4; 0 / 10	2 voices	[51–100%]; [0–28%]	`webrtc_probe.py` · 31a952e / a7eebae	measured†
6	PESQ-WB, seal ±2 dB vs plain Opus 32k	4.61 vs 4.46	10 voices	min 4.60 / 4.41	`quality.py` · 622fe9d	proxy†
3, 7, 8	Routine payments at HOLD, before → after	27.5% → **3.0%**	200	[21.8–34.1] → [1.4–6.4]	`research/alert_budget` → `alert_budget.json` · 7f28b4e (test split unless "all")	measured
7	Routine payments at ≥ VERIFY	36.5% → 21.5%	200	[30.1–43.4] → [16.4–27.7]		measured
7	Attack cases ≥ VERIFY; at HOLD	71.4→76.5%; 25.5→12.2%	98	after: [67.2–83.8]; [7.1–20.2]		measured
7, A3	Splits ≥ VERIFY; payee-change / big new payee ≥ VERIFY (all)	0→100%; 100% / 100%	12; 26 / 75	—		measured
7	Ask precision / recall, frozen lexicon	0.47 / 0.33	73 / 104	[.36–.58] / [.24–.42]	`research/heldout` → `asks_heldout_eval.json` · c6746a9	measured
7	Benign texts with a false ask (→ context layer)	21.0% → 11.5%	157	[15.4–28.1] → [7.4–17.4]		measured
7, 8	Recall EN / Hinglish / Devanagari (all)	0.28 / 0.36 / 0.15	190 asks	Devanagari [.07–.29]		measured
7, A3	Routine at HOLD: 1 secrecy word; OTP-SMS line; 2 types	20.5%; 3.0%; 100%	200	[15.5–26.6]; [1.4–6.4]	`research/redteam` → `redteam_deterministic.json` · c6746a9	measured
7	Asks hidden: wrapper; "never asks OTP … but"	5.3%; 34.2%	38	[1.5–17.3]; [21.2–50.1]		measured
A3	Reassuring summaries passing the checker	100% → 36.7%	30	[21.9–54.5]		measured
1, 7	Automated tests (skipped = unfinished tasks)	561 pass, 138 skip	—	—	`make check` · 2afaf2a	measured

† **Seal rows: synthetic TTS voices** (Kokoro-82M, 6 English + 4 Hindi, n = 10), real codecs (ffmpeg, sox), real Chromium 141; illustrative, not field results. Text rows: AI-written synthetic texts, one author. **Estimates** (cost ≈ ₹1 per case, ≈ ₹2 per live minute) are labelled as such. Full ledger: `results/EVIDENCE_LEDGER.md`.

Known weakness: a constant 3% time-stretch defeats fixed-rate seal checking. **Pending:** seal through real Google Meet; listening test; voice-detector error rate through codecs and Meet; per-speaker false alarms; clone catch rate; ask → chip latency; LLM echo rate; email and invoice checkers. **Withdrawn:** see X4.

External numbers ([R1]-[R4], [R10], [R11], [R13]) are the sources' own, quoted as published and checked on 8 Oct 2026: X6

X2 · Floor table and signal → band table

CODE	FLOOR ACTION (TRUSTED INPUTS ONLY)	FLOOR	CLEARANCE
K1	known payee, same details, usual amount, paid in last 180 days	PASS	none
K2	known payee, amount > 1.25 × 12-month max, or dormant	VERIFY	callback (master number) or OOB
N1	new payee, ≤ ₹25,000 incl. its last 30 days	PASS	bank's own checks
N2	new payee above ₹25,000	VERIFY	callback or OOB; > ₹10 lakh both
C1	vendor's bank / UPI differs from master	VERIFY	callback on old number + bank-shown name = master
T1	phone, email or approver on file changed	HOLD	checker via old channel + 2nd approver
D1	data or credential request only	PASS	unless signals fire
NONE	live call, no payment yet	PASS	—

DECISION RULES

- Band = max(floor, every signal's target); nothing lowers it. Strong signals from ≥ 2 groups ⇒ HOLD (style / LLM never count).
- Policy 1.1: one ask alone ⇒ at most VERIFY unless corroborated (2nd ask type, another non-LLM group, or a risky floor).
- "No, not me" ⇒ HOLD + suspected fraud. Grey flags (parse failure, detector error, short speech, unsupported language) ⇒ ≥ VERIFY + checker queue.
- Clearing changes the status, never the band.

GROUP	SIGNAL (REASON CODE)	STRENGTH	TARGET BAND
sender auth	DMARC fail; look-alike domain	strong	VERIFY; HOLD if floor ≥ VERIFY
	"bank" mail not from a .bank.in domain [R5]	strong	VERIFY
	Reply-To mismatch; free-mail for a company	weak	VERIFY
document	invoice account ≠ vendor master	strong	VERIFY
	PDF edited after creation	weak	VERIFY
media (ML)	likely synthetic voice (2 windows ≥ τ_hi)	strong	one band above floor
	inconclusive voice	weak	none (reason only)
ask	A2 OTP / PIN; A3 remote access	strong	HOLD*
	A4 secrecy; A5 bypass a control	strong	HOLD if money, else VERIFY*
	A1 new account; A6 gift card / crypto; A7 payee change	weak	VERIFY
style (ML / LLM)	pressure language	weak	at most VERIFY
watchlist	flagged sender or caller, 30 days	weak	one band above floor
provenance (Seal)	VOICE_SEALED	weak	**none**: information only
	VOICE_UNSEALED_CLAIMED_EXEC (≥ 15 s, no seal)	weak	VERIFY
	SEAL_PRESENCE_CONFLICT (exec sealing another meeting)	strong	HOLD if money, else VERIFY

* capped at VERIFY unless corroborated (policy 1.1). Email and document signals are specified and tested as contracts; their detectors are not yet built (X4). The table is data in `contracts/signal_table.py`: detectors cannot choose their own strength or target.

[R5] RBI: banks to move to .bank.in domains (deadline 31 Oct 2025) · ₹ thresholds are configuration · ADR-021 (policy 1.1), ADR-022 (30-day de-minimis), ADR-023 (Seal)

X3 · Who attacks, what stops them, and where personal data goes

ATTACKER	CAN DO	MAIN CONTROL
Impersonator on a call	live voice clone or face swap; scripted pressure	floor; Seal; checker HOLD; OOB to the real person
Vendor email compromise	look-alike domain or the vendor's real mailbox; edited PDFs	C1 floor fires on any bank change, whatever the mail says
Prompt injector	instructions hidden in mail, PDF, headers, Hindi text	LLM never sets the band; text is data, not prompt
Oracle tuner	submits fakes again and again	makers see bands only; no public upload
Insider maker	enters payments, uploads, tries to clear	maker cannot clear HOLD or confirm fraud
Compromised exec mailbox	clicks the OOB link for the CFO	OOB needs his own login; Intent Seal needs his passkey
Seal stripper	removes or damages the seal [R9]	result is "not sealed": what he already was
Compromised exec laptop	seals or signs anything once he unlocks	**not defeated**; short sessions, Touch ID per payment

RESIDUAL RISKS, STATED

- A perfect deepfake on a known-vendor, same-account payment can pass, but the money then goes to the genuine vendor.
- A mule account in a look-alike name passes the bank-name check; the floor still forces a callback.
- Paraphrased asks evade the lexicon (page 7); queue flooding with two keyword types still works.
- The first record of a new vendor is the trust root; onboarding checks are designed, not built.

DATA	PROCESSED	STORED, RETENTION	BASIS (TO CONFIRM WITH COUNSEL)
Live call audio (remote side)	on device; transcript locally or Transcribe ap-south-1	**not stored**; a saved 30 s clip: 30 days, longer only for a fraud case	employer: employment / loss prevention; other side: transient processing
Emails, invoices, voice notes	backend, ap-south-1	S3 (encrypted): 90 days or life of case	same
Seal sessions and keys	registry	meeting ID, timing, keys: life of case	exec's opt-in
LLM summaries	Bedrock in-country (prod) / local model (prototype)	case record, life of case	same
Vendor master, directory	backend	while the contract lasts	contract / employment

DPDP Act 2023 and Rules 2025 [R7]: most duties phase in later; we design for them now. No biometric template is created anywhere. No data leaves Indian regions. Reports are drafts a human submits; victim media is never shared with third parties.

MEDIA PROVENANCE, FUTURE

MeitY's IT Amendment Rules 2026 require labels on synthetic content [R6]. Reading such labels or C2PA credentials can only *raise* a band; attackers will not label their fakes, so absence of a label means nothing.

X4 · What exists today, what does not, and what we withdrew

BUILT AND TESTED (PROTOTYPE)

- Contracts, API skeleton, synthetic fixtures (T01)
- Policy engine + property tests (T02), policy 1.1 and 30-day de-minimis
- Ask extractor, EN / Hinglish / Devanagari (T05) + context layer
- Side panel UI on replayed events (T10)
- EN + Hindi text for all 33 reason codes (T14)
- Satyapan Seal: DSP, TESLA chain, registry API, voice-note check, Intent Seal, side-panel chip
- Custody hash chain core (part of T09)
- Evaluation scripts: held-out, alert budget, red-team, seal

IN PROGRESS

- T07 extension capture: code done; **real Meet tab test pending**
- T09 vault: storage, intake and S3 anchor not yet built

NOT YET BUILT

- T03 e-mail parser, T04 domain checks
- T06 console, T08 invoice / PDF checker
- T11 live transcript path
- T12 OOB-Confirm workflow, T13 callback and checker flows
- T15 LLM summary (Ollama locally; Bedrock in production)
- T16 UTR-first report pack
- T17 voice uploads, T18 voice-detector evaluation
- T19-T21 paraphrase-robustness study (plan only)
- T22 demo assets, T24 citizen scam check (stretch)
- Exec-mode sealing in the browser (AudioWorklet) and the in-extension seal check
- AWS deployment; vendor-onboarding checks; small-firm second verifier; meeting-chat notice

138 tests are skipped until these tasks land; they turn on automatically.

WITHDRAWN, NEVER TO BE QUOTED

A voice-detector table (“EER 4% clean, 0% Opus…”) and fitted thresholds were produced by a script that drew random numbers instead of scoring audio. We removed them, reverted the thresholds to “uncalibrated”, and added a test that blocks random-number generators in any result script. The earlier ask-extractor P = R = 1.0 was circular (same authors wrote lexicon and sentences); page 7 shows the held-out numbers instead.

KNOWN LIMITATIONS

- Seal: Meet server side untested; constant time-stretch weakness; protects only enrolled people.
- WebAuthn shows no amount: malware in the CFO’s browser could swap what he signs.
- Desktop Teams / Zoom and phone calls are not seen live (upload instead).
- All text data is synthetic, one author, no inter-annotator check.

X5 · Disclosures: AI assistance, data, models and third-party assets

CATEGORY	ITEM	HOW IT IS USED · LICENCE OR TERMS
AI-generated content	This PDF	Text, layout and diagrams drafted with AI assistance (Anthropic Claude), then reviewed and edited by the team.
	Code	Much of the code was written with AI coding assistants (Claude Code, Gemini CLI, OpenCode-hosted models) under the team's review and automated tests.
	Synthetic data	Held-out test texts (EN / Hinglish / Devanagari) were written by an AI agent; payment cases are built from them by a script; demo people, companies, banks and accounts are fictional (IFSC FAK..., accounts 9999..., *.example).
Synthetic voices	Kokoro-82M TTS, int8 ONNX via kokoro-onnx [R21]	10 stock voices for all Seal measurements and screenshots · model Apache-2.0. No real person's voice is used anywhere.
	Consented team voices (finale)	Only with signed consent forms, kept off the repo; clones only of a consenting teammate's own recordings.
Models	Pascu et al. browser-plugin voice model (ONNX) [R12]	Prototype voice detector, run locally only; **no licence file**: not redistributed; permission requested from the authors. No number in this PDF comes from it.
	OpenAI Whisper / mlx-whisper	Planned local transcription (MIT).
	Llama 3.1 8B via Ollama	Planned local summary in the prototype (Llama 3.1 Community License); Bedrock in production.
	RNNoise model (ffmpeg arnndn)	Used only once, offline, as a stress test on received audio; not shipped.
Datasets	External datasets	**None** is used for any number in this PDF. Planned: public deepfake sets and Hinglish scam corpora, each under its own terms, for evaluation only.
	Confidential data	None. No bank, customer or platform data was used.
Third-party assets	Fonts: Inter, Noto Sans Devanagari, JetBrains Mono	SIL Open Font License 1.1, embedded in this PDF.
	Screenshots	All are of the team's own prototype pages, made from the running API with synthetic data.
	Product names	Google Meet, Teams, Zoom, WhatsApp, Tally, Zoho, SAP and AWS names are used only to describe integrations; no logos are used.
Libraries	py_webauthn, onnxruntime, FastAPI, Pydantic, NumPy, SciPy, Playwright	Open-source licences (BSD / MIT / Apache-2.0).
	ffmpeg, sox, pesq, pystoi	Run as tools in evaluation only (LGPL / GPL tools invoked as separate programs; not linked into the product).

X6 · References

[R1] Starmangalsutra Pvt Ltd (Sky Gold & Diamonds) ₹10.70 crore loss, Jul 2026. The Economic Times; AI Incident Database #1596: incidentdatabase.ai/cite/1596

[R2] SEBI, PR No. 40/2026, 17 Jul 2026, caution on the "Boss Scam". sebi.gov.in/sebi_data/attachdocs/jul-2026/1784288188963.pdf

[R3] Fortune, 17 May 2024, Arup deepfake CFO scam, HK$200M. fortune.com/europe/2024/05/17/arup-deepfake-fraud-scam-victim-hong-kong-25-million-cfo

[R4] Lok Sabha written reply, 22 Jul 2025: ₹22,845.73 crore lost to cyber fraud in 2024 (PTI). theweek.in/wire-updates/business/2025/07/22/del23-lsq-cyber-fraud.html

[R5] RBI: banks to migrate to ".bank.in" by 31 Oct 2025 (Business Standard, 22 Apr 2025). business-standard.com/finance/news/rbi-asks-banks-to-complete-migration-to-bank-in-domain-by-october-31-2025-125042201515_1.html

[R6] MeitY, IT (Intermediary Guidelines and Digital Media Ethics Code) Amendment Rules 2026: labels on synthetically generated information. dsci.in/resource/content/it-amendment-rules-2026

[R7] Digital Personal Data Protection Rules 2025 (PIB, Nov 2025). static.pib.gov.in/WriteReadData/specificdocs/documents/2025/nov/doc20251117695301.pdf

[R8] National Cyber Crime Reporting Portal and helpline 1930. cybercrime.gov.in

[R9] O'Reilly et al., "Deep Audio Watermarks are Shallow", arXiv 2504.10782: removing a watermark does not help an attacker who needs to *add* a valid seal. arxiv.org/abs/2504.10782

[R10] Shykula, Yermakov et al., "DF26: We Cannot Tell Fake From Real Anymore", arXiv 2609.07369 (2026): 69.7% best AUROC; 34.5% for one detector on closed-source generators (Table 3). arxiv.org/abs/2609.07369

[R11] Chandra et al., "Deepfake-Eval-2024", arXiv 2503.02857: AUC −50% video, −48% audio, −45% image. arxiv.org/abs/2503.02857

[R12] Pascu, Oneata, Cucu, Müller, "Detecting Audio Deepfakes on the Edge: Lightweight SSL-Based Detection in a Browser Plugin", arXiv 2606.30780. arxiv.org/abs/2606.30780

[R13] Rabh et al., "CallShield: Secure Caller Authentication over Real-Time Audio Channels", arXiv 2601.09327 (~63 s, pairwise keys). arxiv.org/abs/2601.09327

[R14] TESLA broadcast authentication (Perrig et al.); IETF RFC 4082, "TESLA: A Brief Introduction". rfc-editor.org/rfc/rfc4082

[R15] W3C Web Authentication (WebAuthn) and Secure Payment Confirmation. w3.org/TR/webauthn-3 · w3.org/TR/secure-payment-confirmation

[R16] Zoom + Tools for Humanity World ID beta, May 2026 (biometricupdate.com/202605/zoom-opens-beta-for-world-id-deepfake-verification-in-enterprise-meetings); Beyond Identity RealityCheck for Zoom, Aug 2024 (itbrief.co.uk/story/beyond-identity-launches-realitycheck-for-zoom-security)

[R17] AWS ML Blog, 29 Sep 2026: Claude models in India via Bedrock geographic cross-Region inference ("in." profile, Mumbai + Hyderabad; Guardrails supported). aws.amazon.com/blogs/machine-learning/amazon-bedrock-expands-claude-model-availability-to-india-cross-region-inference

[R18] Amazon Transcribe supported languages: hi-IN and en-IN, batch and streaming. docs.aws.amazon.com/transcribe/latest/dg/supported-languages.html

[R19] Amazon Verified Permissions endpoints (ap-south-1 listed). docs.aws.amazon.com/general/latest/gr/verifiedpermissions.html

[R20] Amazon S3 Object Lock. docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html

[R21] Kokoro-82M (Apache-2.0): huggingface.co/hexgrad/Kokoro-82M · kokoro-onnx: github.com/thewh1teagle/kokoro-onnx

Repository evidence: `results/EVIDENCE_LEDGER.md`, `research/seal/README.md`, `docs/SEAL.md`, `docs/ARCHITECTURE.md`, `docs/DECISIONS.md` (ADR-001 to ADR-023).

Where a figure could not be confirmed at its source it was removed (e.g. "profile cloning" in [R1]; Pascu EER figures not quoted)